IBM i (AS/400) Authorized Pentest Checklist

WebTerm/3270 AS/400 security toolset + the Pentesting the AS/400 audit order -- authorized engagements and training only

Prepared by Britley Hoff | October 14, 2026

Combines the WebTerm/3270 AS/400 security toolset (Bridge_server/public/js/as400sec.js, mock-lpar/mock-as400.js) with the audit order from Pentesting the AS/400 and the operational-judgment scenarios in the Mainframe 101-105 and 200-series learning books. For authorized engagements and training against the bundled mock IBM i LPAR; every item names the real command or button it runs.

How to use this checklist: one item per step, in order. Check the box when the step is done, write what you found on the Notes line before moving on, even if the finding is "ran clean" or "n/a" - a row with no finding is still a row worth a note. Phases 5 and 7 interlock with earlier phases; don't skip ahead.

Items tagged (manual) have no scanner in the toolset yet. They come from the corrected IBM i audit workbook (IBMi_Security_Audit_Corrected.xlsx) and are run by hand with the command shown, tracked on the roadmap. Commands marked confirm on box were not tested on a live IBM i: prompt CL with F4, and for SQL run the view with FETCH FIRST 1 ROW ONLY first, since column names differ by release.

Phase 0 -- Authorization and Scoping

No tool in this phase. Nothing past this point runs without a signed ROE.

- [ ] Signed ROE on file, naming which LPAR, which IBM i release, and the library/object boundary (if any).

Notes: .....

- [ ] ROE states explicitly whether read-only enumeration is authorized versus anything that touches a production object.

Notes: .....

- [ ] Default/shared-credential enumeration is named in the ROE as its own authorized activity, not assumed to be covered by general scope.

Notes: .....

- [ ] Change-window and rollback language confirmed -- IBM i shops often run with less redundancy than assumed.

Notes: .....

- [ ] Data-handling clause covers screen captures: a Sign On banner or a profile list can itself contain production data.

Notes: .....

- [ ] Client sign-off obtained before the first command runs.

Notes: .....

Phase 1 -- Pre-Authentication Recon

Everything here happens before a password is successfully typed.

- [ ] Read the Sign On screen as a disclosure surface -- system name, subsystem, program/library fields.

Notes: .....

- [ ] Record system name, subsystem, and display device id exactly as shown.

Notes: .....

- [ ] Run the Default Credential Audit before signing on for real. Security panel -> Default Credential Audit -> START.

Notes: .....

- [ ] Load any pre-engagement intel (userids from a kickoff call, a directory export) as additional candidates. Load file / Load from host.

Notes: .....

- [ ] Record every SUCCESS, every EXISTS (valid userid, no working password -- still a finding), and whether the run hit a LOCKOUT.

Notes: .....

Phase 2 -- Initial Authenticated Recon

Signed on. Before any drill-down tool, get the shop's overall posture and patch currency.

- [ ] Display network attributes. Command: DSPNETA -- ANALYZE NETWORK ATTRS.

Notes: .....

- [ ] Run the System Value Analyzer. Command: WRKSYSVAL -- ANALYZE SYSTEM VALUES.

Notes: .....

- [ ] Reason out which values should flag before reading the tool's verdict: QSECURITY below 40, QMAXSIGN at NOMAX, QPWDEXPITV at NOMAX, QALWOBJRST at ALL, QAUDCTL at NONE.

Notes: .....

- [ ] The System Value Analyzer now also rates QPWDLMTREP, QPWDLMTCHR, QPWDVLDPGM, QINACTMSGQ, QLMTDEVSSN, QALWUSRDMN, QUSEADPAUT, QRMTSIGN, QRMTSRVATR, QSHRMEMCTL, and the audit values (QAUDLVL, QAUDLVL2, QAUDENDACN, QAUDFRCLVL, QCRTOBJAUD, QFRCCVNRST, QSCANFS, QSCANFSCTL). Reason out which should flag before reading the verdict. (manual) To read any one by hand: SELECT SYSTEM_VALUE_NAME, CURRENT_NUMERIC_VALUE, CURRENT_CHARACTER_VALUE FROM QSYS2.SYSTEM_VALUE_INFO WHERE SYSTEM_VALUE_NAME = '...' (confirm on box). QUSEADPAUT set to NONE is weak, it means anyone can create programs that use adopted authority.

Notes: .....

- [ ] QAUDCTL needs OBJAUD as well as AUDLVL, or object auditing is silently off. The System Value

Analyzer flags a QAUDCTL that is set but missing either one (MEDIUM), and a QAUDLVL missing any of these (MEDIUM): AUTFAIL CREATE DELETE JOBDTA OBJMGT PGMADP PGMFAIL PRTDTA SAVRST SECURITY SPLFDTA SYSMGT AUDLVL2. AUDLVL2 is the switch that makes QAUDLVL2 count. Also reason out QAUDENDACN (NOTIFY lets the box run unaudited) and QAUDFRCLVL (higher is weaker).

Notes: .....

- [ ] Run the PTF/CVE Currency Checker. Command: STRSQL (SYSTOOLS.CVE_INFO(), SYSTOOLS.GROUP_PTF_CURRENCY_LOCAL()) -- CHECK PTF/CVE CURRENCY.

Notes: .....

Phase 3 -- Identity and Privilege Enumeration

- [ ] Enumerate user profiles. Command: WRKUSRPRF -> DSPUSRPRF -- ENUMERATE PROFILES.

Notes: .....

- [ ] Flag special authorities, especially ALLOBJ/SECADM held together -- CRITICAL on their own.

Notes: .....

- [ ] Flag any privileged profile with LMTCPB(NO) -- the limitation compounds the risk, it doesn't just add to it.

Notes: .....

- [ ] Audit the IBM-supplied (Q) profile set. AUDIT SHIPPED PROFILES.

Notes: .....

- [ ] Confirm every shipped profile is non-interactive: STATUS(DISABLED) or PASSWORD(NONE).

Notes: .....

- [ ] Flag any default password on a shipped profile as CRITICAL, regardless of anything else true about it.

Notes: .....

- [ ] Flag a Q-named profile that is NOT on the real IBM-supplied list -- a classic "blend in with a shipped name" persistence technique.

Notes: .....

- [ ] Note the QSECOFR exception: a vaulted break-glass account is legitimate on its own; a default password on it is not.

Notes: .....

- [ ] (manual) Report default passwords the supported way, with no guessing: ANZDFTPWD ACTION(NONE) (report only, needs ALLOBJ and SECADM, confirm on box). Use this for a client-assisted audit. The Default Credential Audit in Phase 1 is guessing, and belongs to a pentest with its own ROE clause.

Notes: .....

- [ ] (manual) Do not recommend disabling QUSER. The control is PASSWORD(NONE), since TCP server prestart jobs run under it and disabling it can break them. Same for QSYSOPR, which owns the operator message queue.

Notes: .....

- [ ] (manual) Review group and supplemental group membership. SELECT AUTHORIZATION_NAME, GROUP_PROFILE_NAME FROM QSYS2.USER_INFO WHERE GROUP_PROFILE_NAME IS NOT NULL, then SELECT FROM QSYS2.GROUP_PROFILE_ENTRIES. Supplemental groups grant rights the primary group query never shows (confirm on box).

Notes: .....

- [ ] (manual) Find objects owned by QSECOFR that should belong to an application owner profile. DSPUSRPRF USRPRF(QSECOFR) TYPE(OBJOWN) OUTPUT(OUTFILE) OUTFILE(QTEMP/OBJOWN) (confirm on box).

Notes: .....

Phase 4 -- Object and Data Authority

- [ ] Scan object authority. Command: WRKOBJ / DSPOBJAUT -- SCAN OBJECT AUTHORITY.

Notes: .....

- [ ] Rate PUBLIC authority first: ALL critical, CHANGE high, USE low.

Notes: .....

- [ ] Check private grants on the object's own authority list -- a non-public user holding ALL/CHANGE on a sensitive object escalates the finding even when PUBLIC looks fine.

Notes: .....

- [ ] Confirm with the client which libraries/objects count as "sensitive" for this engagement (payroll, employee master, configuration) -- do not assume a generic pattern match.

Notes: .....

- [ ] (manual) Check library CRTAUT as well as the QCRTAUT system value. The library setting overrides the system value, so PUBLIC can be wide open on new objects even when QCRTAUT looks fine. DSPLIBD LIB(name). When listing PUBLIC authority with QSYS2.OBJECT_PRIVILEGES, always filter by library, an unfiltered query will crawl.

Notes: .....

Phase 5 -- The Privilege-Escalation Triangle

Three scanners whose findings interlock. Run Phase 3's User Profile scan in the same sitting before Active Jobs -- the Active Job scanner cross-references its in-memory CRITICAL/HIGH list.

- [ ] Scan job descriptions. Command: WRKJOBD -- SCAN JOB DESCRIPTIONS.

Notes: .....

- [ ] Flag a job description whose USER() parameter lets a submitter run batch work under an identity they don't hold -- the platform's own setuid-binary equivalent.

Notes: .....

- [ ] Scan authorization lists. Command: WRKAUTL / DSPAUTL -- SCAN AUTH LISTS.

Notes: .....

- [ ] Treat one overbroad PUBLIC rating on an authorization list as a multiplier -- it covers every object the list secures, all at once.

Notes: .....

- [ ] Scan active jobs. Command: WRKACTJOB -- SCAN ACTIVE JOBS.

Notes: .....

- [ ] Cross-reference: is any profile flagged CRITICAL/HIGH in Phase 3 currently running a job? Weight that finding accordingly.

Notes: .....

Phase 6 -- The Network-Facing Surface

What can reach this box without going through a 5250 sign-on at all.

- [ ] Audit exit points / service registration. Command: WRKREGINF -- AUDIT EXIT POINTS.

Notes: .....

- [ ] Flag a missing or unregistered exit program on a sensitive exit point (FTP, remote command, remote SQL).

Notes: .....

- [ ] The Exit Point audit now also reads these (ratings are a judgment call, not IBM's): QIBM_QZDA_NDB1, QIBM_QZDA_ROI1, QIBM_QZRC_RMT (remote command and program call, the highest risk host server), QIBM_QZSO_SIGNON, QIBM_QTMF_SVR_LOGON, QIBM_QSY_VLD_PASSWRD, QIBM_QTG_DEVINIT, QIBM_QZHQ_DATA_QUEUE. (manual) To read one by hand: SELECT EXIT_POINT_NAME, EXIT_POINT_FORMAT, EXIT_PROGRAM_NAME, EXIT_PROGRAM_LIBRARY FROM QSYS2.EXIT_PROGRAM_INFO WHERE EXIT_POINT_NAME = '...'. The scanner currently labels QIBM_QCA_RTV_COMMAND as the remote command exit, confirm on WRKREGINF which name your release uses before relying on it.

Notes: .....

- [ ] Audit NetServer (SMB) configuration. AUDIT NETSERVER CONFIG.

Notes: .....

- [ ] Check guest access and SMB signing requirements specifically.

Notes: .....

- [ ] Sweep IFS permissions. Command: WRKLNK -- SWEEP IFS PERMISSIONS.

Notes: .....

- [ ] Evaluate by owner and PUBLIC authority the same way as a native object -- under the hood, it is one.

Notes: .....

Phase 6A -- Listening Services Inventory (manual)

No scanner yet. Same question as Phase 6, answered from the network side. Command for each: SELECT LOCAL_ADDRESS, LOCAL_PORT, TCP_STATE FROM QSYS2.NETSTAT_INFO WHERE LOCAL_PORT IN (...) (confirm on box), or WRKTCPSVR SERVER(name).

- [ ] Telnet: clear text on 23 should be off, 5250 over TLS is 992, not 993 (993 is IMAP over TLS). Confirm no clear text listener remains.

Notes: .....

- [ ] Host servers (ODBC, JDBC, remote command, file, data queue): clear 8470 to 8476, TLS 9470 to 9476. TLS only, with exit points registered. 8473 (file) and 8475 (remote command) are high risk.

Notes: .....

- [ ] FTP 21 (explicit TLS) and 990 (implicit TLS), TFTP 69 UDP (no authentication, disable), REXEC 512 (clear text credentials, disable).

Notes: .....

- [ ] DDM and DRDA: 446 is clear, 448 is TLS. Require 448 or restrict by IP.

Notes: .....

- [ ] SNMP 161 and 162 UDP: disable or SNMPv3 only, review community names with CHGSNMPA.

Notes: .....

- [ ] LPD 515: LPR has no authentication, so it bypasses output queue controls. Disable or restrict by IP.

Notes: .....

- [ ] NFS 111 and 2049: disable unless required, restrict exports to named hosts. NetServer 137 to 139 and 445: guest access off, SMB signing required.

Notes: .....

- [ ] HTTP and Navigator: HTTPS only. IBM Navigator and the HTTP Server Administration GUI on 2001 (clear) and 2010 (TLS), restrict by IP or VPN. Run the HTTP Admin GUI Audit under the RoE Scope Guard, ports 2001 and 2010 must be named in the ROE.

Notes: .....

- [ ] APPC and APPN are SNA, not IP. Check WRKCFGSTS CFGTYPE(CTL) and CFGTYPE(LIN) for anything still active.

Notes: .....

Phase 7 -- Adopted Authority and Live Bypass Testing

Authority leaking past a boundary the shop thinks it has drawn. The bypass probe actually drives screens and issues real commands -- confirm the ROE covers active testing, not just enumeration, before this phase.

- [ ] Scan the call stack for adopted authority. Command: WRKJOB OPTION(PGMSTK) -> DSPPGM -- SCAN CALL STACK.

Notes: .....

- [ ] Flag any program that adopts an owner's authority where the owner is a privileged profile.

Notes: .....

- [ ] Run the Menu/Command-Line Bypass Probe. PROBE FOR BYPASSES.

Notes: .....

- [ ] Confirm whether LMTCPB(YES) on the sign-on session actually reaches each stock utility's command line (WRKSPLF, WRKOUTQ, WRKJOBD, WRKUSRJOB, WRKACTJOB) -- the limit is checked at sign-on, not necessarily on every later screen.

Notes: .....

- [ ] Note which screens held the restriction and which quietly didn't.

Notes: .....

Phase 7A -- Spool, Auditing, and Integrity (manual)

No scanner yet. Evidence for these comes from journal entries and queries, not a screen.

- [ ] Static adopted-authority scan across a whole library, not just the live call stack: SELECT PROGRAM_LIBRARY, PROGRAM_NAME, PROGRAM_OWNER FROM QSYS2.PROGRAM_INFO WHERE USER_PROFILE = 'OWNER' AND PROGRAM_LIBRARY = 'yourlib', and DSPPGMADP USRPRF(QSECOFR) per ALLOBJ owner. The finding is USRPRF(OWNER) on a program owned by a powerful profile. Ownership alone is not the risk, and neither is USEADPAUT.

Notes: .....

- [ ] PUBLIC on production programs should be no more than USE. SELECT FROM QSYS2.OBJECT_PRIVILEGES WHERE USER_NAME = 'PUBLIC' AND OBJECT_TYPE = 'PGM' AND SYSTEM_OBJECT_SCHEMA = 'yourlib'.

Notes: .....

- [ ] Output queue inventory and authority: SELECT FROM QSYS2.OUTPUT_QUEUE_INFO, then PUBLIC on each sensitive OUTQ (EXCLUDE expected). Check DSPDTA(OWNER), AUTCHK(DTAAUT), OPRCTL(NO) on sensitive queues, since OPRCTL(YES) lets anyone with JOBCTL read everything. Also QUSRSYS/QPJOBLOG and QGPL/QPRINT.

Notes: .....

- [ ] Who can read any spool file: holders of SPLCTL and JOBCTL. SELECT AUTHORIZATION_NAME FROM QSYS2.USER_INFO WHERE SPECIAL_AUTHORITIES LIKE '%SPLCTL%' OR SPECIAL_AUTHORITIES LIKE '%JOBCTL%'. SPLCTL bypasses queue security completely.

Notes: .....

- [ ] Sensitive queue list is signed by application owners, with the data classification of each. This is a procedure, the evidence is the signed list.

Notes: .....

- [ ] Audit journal review. DSPJRN JRN(QSYS/QAUDJRN) ENTTYP(...) OUTPUT(OUTFILE) for restores (OR RA RO RP, needs SAVRST), creates and program changes (CO ZC OR, needs CREATE and object auditing at CHANGE), spool (SF, needs SPLFDTA) and print (PO, needs PRTDTA). Entries match change tickets, and QALWOBJRST is NONE outside restore windows.

Notes: .....

- [ ] Exit program integrity: list them from QSYS2.EXIT_PROGRAM_INFO, then CHKOBJITG (prompt with F4 for scope). Check PUBLIC is no more than USE on each exit program and its library.

Notes: .....

- [ ] There is no native hash command for a program object. Baseline with object signing plus CHKOBJITG, or store QSYS2.OBJECT_STATISTICS output off the box and compare.

Notes: .....

Phase 8 -- Reporting

- [ ] Export every tool's findings. Export CSV / JSON on each panel.

Notes: .....

- [ ] Write an executive summary a non-technical stakeholder can act on.

Notes: .....

- [ ] Rank findings by real exploitability, not one flattened severity scale.

Notes: .....

- [ ] Separate a narrow fix (disable one shipped profile) from a structural one (no process exists to review adopted-authority programs at all).

Notes: .....

- [ ] Time the report's release around the client's own change windows, not your own convenience.

Notes: .....

- [ ] Keep an exception register of legitimate changes (library, object, type, owner, approver, change ticket) and review it quarterly, so a finding that was approved is not reported again as new.

Notes: .....

- [ ] Assemble an evidence pack per review cycle: date, reviewer, system, and the exported results. Exporting query output to the IFS with CPYTOIMPF works. Screenshots of monitoring samples go in the

evidence pack, not in the checklist as a control.

Notes: .....

Where the Mock Stops

Every tool here was built and verified against WebTerm/3270's open-source mock IBM i LPAR, not a real customer system. The mock's shipped-profile list is the common base plus common-LP set; a real shop layers in whatever licensed products it has installed, each with its own service profiles to research, not assume. Exit-point findings here mean "nothing is positioned to intercept this," not "the actual exit program has a flaw" -- real exit programs are custom code the mock doesn't model the behavior of. Items tagged (manual) are not built into the toolset or the mock at all, and the corrected commands behind them came from a reviewed workbook, not a live system. Treat every item's command and risk language as a starting point for what to ask a real system, not a claim about what a real system will show.

Project reference: Bridge_server/DOCUMENTATION/webterm-security-tools-tutorial.md and webterm-security-tools-cheat-sheet.md cover this toolset and the rest of WebTerm/3270's security tooling (z/OS, z/VM, z/TPF) in more depth.